

Project 01: EMAIL THREAT INVESTIGATION & ANALYSIS REPORT

Project: Email Threat Investigation & Analysis

Case File: CA-ETI-01

Prepared By: Shantanu Gayke

Intern ID: CA0149

Date: 22 July 2026

Table of Contents

Sr. No.	Section	Page No.
1	Executive Summary	3
2	Methodology	4
3	Email 01 Analysis	5-6
4	Email 02 Analysis	7-8
5	Email 03 Analysis	9-10
6	Email 04 Analysis	11-12
7	Email 05 Analysis	13-14
8	Email 06 Analysis	15-16
9	Email 07 Analysis	17-18
10	Email 08 Analysis	19-20
11	Email 09 Analysis	21-22
12	Email 10 Analysis	23-24
13	Email 11 Analysis	25-26
14	Email 12 Analysis	27-28
15	Email 13 Analysis	29-30
16	Per Email Findings Summary	31-32
17	Consolidated Indicators of Compromise (IOC)	33-34
18	Recommendations	35
19	Conclusion	36

Executive Summary

This investigation was conducted to analyse thirteen recovered emails from the mailbox of Mr. Aditya Rao, Senior Finance Executive at Solvex Industries Pvt. Ltd., with the objective of identifying legitimate business communications, phishing attempts and other potentially malicious emails. Each email was examined by analysing its technical headers, including the sender address, Reply-To, Return-Path, SPF, DKIM, DMARC and encryption status. The email content, attachments, embedded links and possible social engineering techniques were also reviewed before assigning a final risk classification.

Out of the 13 recovered emails, 5 emails were classified as SAFE, 2 as MEDIUM RISK and 6 as SUSPICIOUS. The safe emails were legitimate communications originating from trusted domains and passed all authentication checks without containing any malicious indicators. The medium-risk emails appeared technically legitimate but involved requests such as changes to vendor banking details or sharing sensitive personal information, which require independent verification before taking any action. The suspicious emails showed clear signs of phishing, executive impersonation, advance fee fraud and malware delivery attempts. Common indicators included spoofed or lookalike domains, failed email authentication, suspicious Reply-To addresses, macro-enabled attachments, phishing links and the use of urgency, authority, fear or financial rewards to manipulate the recipient into acting without proper verification.

Overall, the investigation highlights that technical authentication alone should never be used as the only factor when determining whether an email is safe. Some malicious emails successfully impersonated trusted individuals or used convincing business scenarios to bypass suspicion, while others clearly failed authentication and contained obvious indicators of compromise. A complete email investigation should always combine technical header analysis with contextual review of the email content and the sender's request before making a final decision.

Based on these findings, users should avoid interacting with suspicious links or attachments, never enable macros in documents received through email unless verified, independently confirm any request involving financial transactions or banking detail changes, and report suspicious emails to the Information Security Team for further investigation. Following these practices can significantly reduce the risk of phishing attacks, Business Email Compromise (BEC), malware infections and financial fraud within the organisation.

Final Classification Summary:

SAFE: 5 Emails

MEDIUM RISK: 2 Emails

SUSPICIOUS: 6 Emails

Methodology

Each email was analysed using the following investigation process:

- Verification of sender email address and display name
- Comparison of Reply-To and Return-Path addresses
- SPF, DKIM and DMARC validation
- Inspection of embedded URLs without visiting them
- Attachment type analysis
- Identification of social engineering techniques
- IOC extraction
- Risk classification

EMAIL 01: Password Expiry Reminder – Action Needed Within 5 Days

Risk Level: Low

Verdict: SAFE

Technical Header Analysis

Sender: IT Helpdesk – Solvex Industries <ithelpdesk@solvexindustries.com>

Reply-To: <ithelpdesk@solvexindustries.com>

Return-Path: ithelpdesk@solvexindustries.com

SPF: Pass

DKIM: Pass

DMARC: Pass

TLS Encryption: Enabled (TLS 1.3)

Observation

The sender address, Reply-To address and Return-Path are identical and belong to the official company domain. SPF, DKIM and DMARC validation all passed successfully, indicating that the email was authorised by the domain owner. The message was also transmitted over an encrypted TLS connection and originated from the organisation's internal mail server. These indicators strongly support the legitimacy of the email.

Email Content Analysis

The email informs the employee that the corporate password will expire within five days and explains the official procedure for changing it using the internal IT Service Portal. The message does not ask the recipient to share credentials through email or provide sensitive information. It also reminds employees never to disclose passwords to anyone, including the IT department, which reflects good organisational security practice. The language used is professional and informative rather than threatening or manipulative.

Social Engineering Analysis

No social engineering techniques were identified. The email does not create unnecessary urgency, use fear tactics or attempt to pressure the recipient into making an immediate decision.

Link / Attachment Analysis

No external or suspicious links were found.

No attachment was included.

Indicators of Compromise (IOCs)

No Indicators of Compromise were identified.

Risk Justification

This email is classified as **SAFE** because all technical authentication mechanisms were successfully validated, the sender information is consistent throughout the email headers, and no malicious links, attachments or social engineering techniques were identified. The message follows the organisation's standard password management policy and promotes secure behaviour rather than requesting confidential information.

Recommended Action

The employee may safely follow the password change instructions using the official internal IT Service Portal. No incident response action is required.

EMAIL 02: Your Mailbox Storage is FULL – Verify Now to Avoid Suspension

Risk Level: High

Verdict: Suspicious

Technical Header Analysis

Sender: IT Support Desk <support@solvex-industries-helpdesk.com>

Reply-To: <recovery-team@mail-secure-verify.net>

Return-Path: bounce@mail-secure-verify.net

SPF: Fail

DKIM: Fail

DMARC: Fail

TLS Encryption: Unencrypted

Observation

The sender address, Reply-To address and Return-Path are different and belong to the suspicious domain. SPF, DKIM and DMARC all validation is failed. Indicating server didn't have authorization to send mail and signature of mail was not verified. Although the sender's DMARC policy specified rejection, the receiving mail server accepted the email instead of rejecting it. These indicate that the email is highly suspicious.

Email Content Analysis

The email claims that the recipient's mailbox storage has exceeded its allocated limit of 5 GB and warns that the account will be suspended if no action is taken within 24 hours. It instructs the recipient to click on an embedded link and verify their login credentials to restore mailbox access. The message uses urgency by imposing a strict time limit and **fear** by threatening permanent loss of email access and stored data. These are common social engineering techniques used in phishing attacks to pressure users into acting without verifying the legitimacy of the request. Additionally, the email directs the user to an external verification link instead of the organisation's official portal, indicating an attempt to steal login credentials. Therefore, the content strongly suggests that this is a phishing email.

Social Engineering Analysis

Several social engineering techniques were identified. The creates urgency by using words like IMMEDIATELY, use fear tactics i.e. access to the account will be lost or attempt to pressure the recipient to click on the suspicious external link

Link / Attachment Analysis

Embedded suspicious link that look alike company domain.

hxxp://solvex-industries-helpdesk.verify-account-secure.com/mailbox/confirm?user=aditya.rao

Indicators of Compromise (IOCs)

- Suspicious sender domain: **solvex-industries-helpdesk.com**
- External Reply-To address: **mail-secure-verify.net**
- Suspicious Return-Path domain: **mail-secure-verify.net**
- Source IP: **193.41.77.108**
- Phishing URL: **hxxp://solvex-industries-helpdesk.verify-account-secure.com/mailbox/confirm?user=aditya.rao**

Risk Justification

This email is classified as **SUSPICIOUS** because all technical authentication mechanisms were failed, the sender information is inconsistent throughout the email headers, and there is a malicious embedded link and also social engineering techniques were identified. The message is phishing and if recipient clicks on the link and enters the login credentials, may lose the access to the account.

Recommended Action

The employee strictly should not click on the link provided and report the mail immediately to the IT team and report the mail as spam, so that appropriate actions will be taken.

EMAIL 03: Invoice SI-4471 & Updated Bank Details for Future Payments

Risk Level: Medium

Verdict: MEDIUM RISK

Technical Header Analysis

Sender: Ramesh Kulkarni – Accounts, Apex Steel Traders<ramesh.kulkarni@apex-steeltraders.co>

Reply-To: accounts.payments@apexsteel-billing.com

Return-Path: ramesh.kulkarni@apex-steeltraders.co

SPF: Pass

DKIM: Pass

DMARC: Pass

Encryption: TLS 1.2 Enabled

Observation

The sender's domain successfully passed SPF, DKIM and DMARC authentication checks, indicating that the email was genuinely sent from the **apex-steeltraders.co** mail server. However, the **Reply-To** address points to a different domain (**apexsteel-billing.com**) instead of the sender's original domain. This inconsistency is unusual and should be treated as suspicious. The authentication proves the email originated from the claimed domain, but it does not confirm that the payment request itself is legitimate.

Email Content Analysis

The email contains a legitimate-looking invoice for a recent steel consignment and requests that **all future payments be sent to a new bank account** due to an alleged banking audit. The sender asks the finance team to treat the request as a priority because they need to close their quarterly accounts before the 10th. Changing bank account details through email is a common tactic used in **Business Email Compromise (BEC)** and vendor payment fraud. Even though the message appears professional and references a genuine business transaction, such requests should never be accepted without independent verification through a trusted communication channel.

Social Engineering Analysis

The email does not use fear or obvious threats. Instead, it applies **business urgency** by mentioning quarter-end financial deadlines and encouraging immediate payment. This creates pressure on the recipient to act quickly without verifying the request.

Attachment Analysis

The attached PDF invoice (**Invoice_SI-4471_Apex_Steel.pdf**) appears to be a standard business document and does not show obvious signs of malware based on the provided information. However, because it contains updated banking details, the attachment should be reviewed carefully before processing any payment.

Indicators of Compromise (IOCs)

- Reply-To domain differs from the sender's domain (apexsteel-billing.com).
- Request to update bank account details.
- Urgent payment request linked to quarter-end closing.

Risk Justification

Although all authentication mechanisms passed successfully, the email requests an immediate change in banking details, which is a well-known Business Email Compromise technique. The Reply-To address belongs to a different domain, adding further suspicion. Because there is insufficient evidence to confirm fraud but enough indicators to require verification, this email is classified as **Medium Risk**.

Recommended Action

Do **not** update the vendor's bank account details based solely on this email. Contact Apex Steel Traders using their previously registered phone number or official contact details to confirm the request. Payment should only be processed after successful verification.

EMAIL 04: Revised Leave & Work-From-Home Policy – Effective 15 July 2026

Risk Level: Low

Verdict: SAFE

Technical Header Analysis

Sender: Human Resources – Solvex Industries <hr@solvexindustries.com>

Reply-To: < hr@solvexindustries.com >

Return-Path: hr@solvexindustries.com

SPF: Pass

DKIM: Pass

DMARC: Pass

TLS Encryption: Enabled (TLS 1.3)

Observation

The sender address, Reply-To address and Return-Path are identical and belong to the official company HR domain. SPF, DKIM and DMARC validation all passed successfully, indicating that the email was authorised by the domain owner. The message was also transmitted over an encrypted TLS connection and originated from the organisation's internal mail server and IP. These indicators strongly support the legitimacy of the email.

Email Content Analysis

The email explains the changes in Leave and Work-From-Home policy of company which has already communicated in town hall of last month. Also to get complete document employee can access I ton HR portal by logging in with credentials. Also, employee can reach out to respective HR if they have any queries or attend the Q&A session scheduled in conference room 2. There is no social engineering techniques used in content writing and also the language of mail is clean and clear and instructions are professional. Thus, the above reasons supports that the mail is legitimate.

Social Engineering Analysis

No social engineering techniques were identified. The email does not create unnecessary urgency, use fear tactics or attempt to pressure the recipient into making an immediate decision.

Link / Attachment Analysis

No external or suspicious links were found.

No attachment was included.

Indicators of Compromise (IOCs)

No Indicators of Compromise were identified.

Risk Justification

This email is classified as **SAFE** because all technical authentication mechanisms were successfully validated, the sender information is consistent throughout the email headers, and no malicious links, attachments or social engineering techniques were identified. The message is reminding about the changes in Policy of company and also states to contact the respective professionals if any query arises.

Recommended Action

The Employee should read the policy document carefully and attend the session scheduled on 12th July at 4:00 PM, in conference room 2.

EMAIL 05: Confidential – Immediate Wire Transfer Required (Time Sensitive)

Risk Level: High

Verdict: SUSPICIOUS

Technical Header Analysis

Sender: Rajeev Malhotra (Managing Director) <rajeev.malhotra.md@gmail-corpmail.com>

Reply-To: rajeev.malhotra.md@gmail-corpmail.com

Return-Path: rajeev.malhotra.md@gmail-corpmail.com

SPF: None (No SPF Record)

DKIM: None

DMARC: None

Encryption: No (TLS Not Enabled)

Observation

The email claims to be sent by the Managing Director of the company, but the sender uses the domain **gmail-corpmail.com** instead of the official **solvexindustries.com** domain. The domain itself appears to imitate a legitimate corporate email service. Additionally, SPF, DKIM and DMARC authentication are not configured, making it impossible to verify the authenticity of the sender. The absence of TLS encryption further increases the risk associated with this email. These technical indicators strongly suggest that the sender cannot be trusted.

Email Content Analysis

The email requests an urgent international wire transfer of **USD 18,500** for a confidential acquisition. The sender claims to be in a board meeting and asks the recipient **not to contact anyone in the Accounts department** or discuss the transaction with colleagues. Instead, the recipient is instructed to wait for bank details in the next email and complete the transfer within one hour. This request bypasses the organisation's normal financial approval process and attempts to isolate the recipient from verifying the instruction, which is a common technique used in Business Email Compromise (BEC) attacks.

Social Engineering Analysis

The attacker uses multiple social engineering techniques:

- **Authority:** Pretends to be the Managing Director.
- **Urgency:** Demands completion of the transfer within one hour.
- **Secrecy:** Instructs the employee not to discuss the request with anyone.
- **Trust Exploitation:** Uses the senior executive's identity to influence the employee into bypassing standard procedures.

Link / Attachment Analysis

No links or attachments are included in this email. The objective of the attack is not malware delivery but fraudulent financial transfer through social engineering.

Indicators of Compromise (IOCs)

- Lookalike sender domain: gmail-corpmail.com
- Missing SPF record
- Missing DKIM signature
- Missing DMARC policy
- No TLS encryption
- Unusual request for an urgent international wire transfer
- Request to keep the transaction confidential

Risk Justification

Although the email does not contain any malicious attachment or phishing link, it exhibits several characteristics of a **Business Email Compromise (BEC)** attack. The use of a lookalike domain, lack of email authentication, urgent financial request and insistence on secrecy indicate a high likelihood of fraud. Processing the requested payment without verification could result in significant financial loss.

Recommended Action

Do not process the requested wire transfer. Verify the request directly with the Managing Director through an official company phone number or another trusted communication channel. Report the email to the Information Security Team and block the sender's domain if confirmed to be malicious.

EMAIL 06: Q1_Vendor_Compliance_Report.xlsx' has been shared with you

Risk Level: Low

Verdict: SAFE

Technical Header Analysis

Sender: Google Drive<drive-shares-noreply@google.com>

Reply-To: drive-shares-noreply@google.com

Return-Path: drive-shares-noreply@google.com

SPF: Pass

DKIM: Pass

DMARC: Pass

Encryption: Yes (TLS 1.3)

Observation

The sender address, Reply-To address and Return-Path are identical and belong to Google's official domain. All authentication mechanisms (SPF, DKIM and DMARC) passed successfully, confirming that the email originated from Google's legitimate mail infrastructure. The email was also transmitted over a secure TLS connection, and the sending server belongs to Google. No abnormalities were identified in the email headers.

Email Content Analysis

The email notifies the recipient that **Priya Menon**, a colleague from Solvex Industries, has shared a Google Sheets document titled "**Q1_Vendor_Compliance_Report.xlsx**". The message includes a short note explaining that the document is required for an upcoming finance audit and requests the recipient to review the highlighted rows before Friday. The content is relevant to the recipient's job role and follows a normal business workflow. Unlike phishing emails, it does not ask the user to provide passwords, financial details or other sensitive information. The email simply informs the recipient about a shared document and provides the standard Google Drive access option.

Social Engineering Analysis

No social engineering techniques were identified.

Link Analysis

The email contains a legitimate Google Drive link that directs the user to a shared spreadsheet. The URL belongs to the official **google.com** domain and matches the expected format of Google Drive sharing notifications. No suspicious or deceptive links were observed.

Indicators of Compromise (IOCs)

No Indicators of Compromise (IOCs) were identified.

Cross Verification

No external verification was required because the email passed all authentication checks, originated from Google's official domain, and contained no suspicious indicators.

Risk Justification

This email is classified as **SAFE** because all authentication mechanisms passed successfully, the sender information is consistent, and the content is relevant to the recipient's work. The email originates from Google's official infrastructure and does not attempt to collect credentials, install malware or manipulate the recipient through social engineering.

Recommended Action

The recipient can safely access the shared document after confirming that the request is expected. As a general security practice, users should always verify the sender and ensure that shared files are relevant to their work before opening them.

EMAIL 07: Unusual sign-in activity detected on your Microsoft account

Risk Level: High

Verdict: SUSPICIOUS

Technical Header Analysis

Sender: Microsoft Account Team<security-noreply@micros0ft-online.com>

Reply-To: no-reply@micros0ft-online.com

Return-Path: bounce@micros0ft-online.com

SPF: Fail

DKIM: Fail

DMARC: Fail

Encryption: No (TLS Not Enabled)

Observation

At first glance, the sender appears to be Microsoft. However, the sender domain is **micros0ft-online.com**, where the letter "o" has been replaced with the number "0". This is a common **typosquatting** technique used to impersonate trusted brands. Additionally, SPF, DKIM and DMARC authentication all failed, indicating that the sender could not be verified. The email was also transmitted without TLS encryption and originated from an unknown external host rather than Microsoft's official mail infrastructure. These indicators strongly suggest that the email is fraudulent.

Email Content Analysis

The email claims that an unusual sign-in attempt was detected from **Lagos, Nigeria**, and warns that the recipient's Microsoft account has been temporarily restricted. It instructs the user to verify their identity within **12 hours** by clicking the provided link. The message is designed to create panic and convince the recipient that immediate action is required. Instead of directing users to Microsoft's official website, it provides a suspicious link that is likely intended to steal login credentials.

Social Engineering Analysis

The attacker uses multiple social engineering techniques to manipulate the recipient:

- **Fear:** Claims the account has been compromised.

- **Urgency:** Gives only 12 hours to verify the account.
- **Authority:** Pretends to be the Microsoft Security Team.
- **Credential Harvesting:** Encourages the user to log in through a fake verification page.

Link Analysis

The embedded link points to: <https://login.microsoftonline.com/secure/verify-identity>

Although the URL appears similar to Microsoft's official login page, the domain contains the number **0** instead of the letter **o**, making it a deceptive phishing domain. Users who enter their Microsoft credentials on this page risk having their accounts compromised.

Indicators of Compromise (IOCs)

- Sender domain: microsoftonline.com
- Reply-To domain: microsoftonline.com
- Return-Path: bounce@microsoftonline.com
- Phishing URL: <https://login.microsoftonline.com/secure/verify-identity>
- Source IP: 77.91.134.6

Risk Justification

This email displays multiple indicators of a credential phishing attack, including a typosquatted domain, failed email authentication, a deceptive login page and strong social engineering techniques. If the recipient enters their credentials on the fake website, the attacker could gain unauthorized access to the user's Microsoft account, emails and other connected services.

Recommended Action

Do not click the embedded link or enter any login credentials. If account verification is required, access Microsoft services only through the official website by manually entering the URL in the browser. Report the email to the Information Security Team and block the sender's domain if confirmed to be malicious.

EMAIL 08: Exciting Career Opportunity – Senior Finance Role (Immediate Response Needed)

Risk Level: Medium

Verdict: MEDIUM RISK

Technical Header Analysis

Sender: Neha Kapoor, HR Consultant<neha.kapoor.hr@talentbridge-recruiters.net>

Reply-To: neha.kapoor.hr@talentbridge-recruiters.net

Return-Path: neha.kapoor.hr@talentbridge-recruiters.net

SPF: Pass

DKIM: Pass

DMARC: None (No Policy Published)

Encryption: Yes (TLS 1.2)

Observation

The sender, Reply-To and Return-Path addresses are consistent, and both SPF and DKIM authentication checks passed successfully. However, the sender belongs to an external recruitment domain that is not associated with the recipient's organisation. Additionally, no DMARC policy is published for the domain, which slightly reduces confidence in the sender's email security. While the technical headers do not indicate direct spoofing, they also do not guarantee that the recruitment offer is genuine.

Email Content Analysis

The email claims that the recipient has been shortlisted for a **Senior Finance Manager** position with a leading MNC offering a salary **40% higher than the industry average**. It requests a response within **24 hours** and asks the recipient to provide a scanned copy of their **latest salary slip** and **PAN card** for verification. Although recruiters often request documents during the hiring process, asking for sensitive personal documents at the initial stage without a confirmed interview or verified employer should be treated cautiously. The attractive salary offer and short response deadline are additional factors that warrant verification before sharing any confidential information.

Social Engineering Analysis

- **Curiosity:** Attractive job opportunity with a reputed company.
- **Reward:** Promises a salary 40% higher than the industry average.
- **Urgency:** Requests a response within 24 hours.
- **Information Harvesting:** Requests sensitive personal documents before establishing trust.

Attachment Analysis

The email contains a ZIP archive named **JD_SeniorFinanceManager_Client.zip**. ZIP files are frequently used to compress legitimate documents, but they are also commonly abused to distribute malware or hide malicious files. Since the attachment's contents are unknown, it should not be opened without first scanning it using antivirus software or a sandbox environment.

Indicators of Compromise (IOCs)

- External recruitment domain: talentbridge-recruiters.net
- ZIP attachment: JD_SeniorFinanceManager_Client.zip
- No DMARC policy published.
- Request for sensitive documents (PAN card and salary slip).

Risk Justification

The email passes SPF and DKIM authentication and does not show signs of spoofing. However, the recruitment offer comes from an unknown external organisation, requests sensitive personal documents at an early stage, and includes a ZIP attachment. These factors introduce a level of risk that requires independent verification before any action is taken. Therefore, the email is classified as **Medium Risk**.

Recommended Action

Do not open the ZIP attachment or share personal documents until the recruiter and the organisation have been independently verified. Confirm the company's legitimacy through official channels and scan the attachment using trusted security tools before opening it.

EMAIL 09: Your TallyPrime Cloud Subscription Renewal Invoice – INV-88213

Risk Level: Low

Verdict: SAFE

Technical Header Analysis

Sender: Tally Solutions Billing<billing@tallysolutions.com>

Reply-To: billing@tallysolutions.com

Return-Path: billing@tallysolutions.com

SPF: Pass

DKIM: Pass

DMARC: Pass

Encryption: Yes (TLS 1.3)

Observation

The sender address, Reply-To address and Return-Path are identical and belong to the official **tallysolutions.com** domain. SPF, DKIM and DMARC authentication checks all passed successfully, confirming that the email originated from the legitimate Tally mail server. The email was also transmitted over a secure TLS 1.3 connection. No inconsistencies or suspicious header information were identified.

Email Content Analysis

The email informs the recipient that the **TallyPrime Cloud annual subscription** is due for renewal and includes an invoice for **₹32,500**. It clearly states that payment should be made through the existing registered payment method or the bank account already on record. Unlike fraudulent invoice emails, it does **not** request a change in bank account details or ask the recipient to share sensitive information. The message is professionally written, contains relevant billing information and follows a standard subscription renewal process, making it consistent with a genuine business communication.

Social Engineering Analysis

No social engineering techniques were observed in this email.

Attachment Analysis

The attached file **INV-88213_TallyPrime_Renewal.pdf** appears to be a standard invoice provided for billing purposes. There is no indication that the attachment contains malicious content, and no suspicious instructions are given to enable macros or download additional files.

Indicators of Compromise (IOCs)

No Indicators of Compromise (IOCs) were identified.

Risk Justification

The email is classified as **SAFE** because it originates from Tally's official domain, passes SPF, DKIM and DMARC authentication, and follows a normal subscription renewal process. The payment instructions do not introduce any new bank account details or request confidential information, reducing the likelihood of fraud.

Recommended Action

The recipient may review the attached invoice and process the renewal through the official Tally Customer Portal or the organisation's standard payment process. As a general security practice, all financial transactions should continue to follow the company's internal approval procedures.

EMAIL 10: CONGRATULATIONS!!! YOU HAVE WON USD 1,000,000 IN THE INTERNATIONAL EMAIL LOTTERY

Risk Level: High

Verdict: SUSPICIOUS

Technical Header Analysis

Sender: INTERNATIONAL LOTTERY BOARD<claims.department009@yandex-mailer.com>

Reply-To: agent.williams.claims@outlook-verify.info

Return-Path: claims.department009@yandex-mailer.com

SPF: Fail

DKIM: Fail

DMARC: Fail

Encryption: No (TLS Not Enabled)

Observation

The email claims to be from an international lottery organisation, but the sender uses a **yandex-mailer.com** address instead of an official lottery domain. The Reply-To address redirects responses to a completely different domain (**outlook-verify.info**), which is highly suspicious. Additionally, SPF, DKIM and DMARC authentication all failed, meaning the sender's identity could not be verified. The email was also transmitted without TLS encryption, further reducing its credibility. These technical indicators strongly suggest that the email is fraudulent.

Email Content Analysis

The email informs the recipient that they have supposedly won **USD 1,000,000** in an international email lottery. To claim the prize, the recipient is instructed to provide personal details, including their full name, address, phone number and a copy of their identification document. The sender also requests a **USD 250 processing and courier fee** before releasing the prize. Legitimate lotteries do not ask winners to pay fees in advance or provide sensitive personal information through email. The combination of an unexpected prize, advance payment request and collection of personal documents is a well-known indicator of an **Advance Fee Fraud** scam.

Social Engineering Analysis

The attacker uses several social engineering techniques to manipulate the recipient:

- **Greed / Reward:** Promises a prize of USD 1,000,000.

- **Urgency:** Gives only 48 hours to claim the prize.
- **Financial Manipulation:** Requests a processing fee before releasing the winnings.
- **Information Harvesting:** Collects personal and identity documents that could later be used for identity theft.

These tactics are commonly observed in lottery and prize scam campaigns.

Link Analysis

The email contains the following embedded URL:

`hxxp://claim-your-prize-now.lottery-verify.info/claim?ref=44921`

The domain **lottery-verify.info** is unrelated to any recognised lottery organisation and appears to have been created solely to support the scam. Visiting this link could expose the user to phishing pages or additional fraudulent payment requests.

Indicators of Compromise (IOCs)

- Sender email: `claims.department009@yandex-mailer.com`
- Reply-To address: `agent.williams.claims@outlook-verify.info`
- Phishing domain: `lottery-verify.info`
- Embedded URL: `hxxp://claim-your-prize-now.lottery-verify.info/claim?ref=44921`
- Source IP: `185.220.101.44`

Risk Justification

This email exhibits all the characteristics of a classic **Advance Fee Fraud (Lottery Scam)**. The unexpected prize announcement, advance payment request, collection of sensitive personal information, suspicious sender addresses and failed authentication checks indicate a high probability of fraud. If the recipient follows the instructions, they may suffer financial loss and identity theft.

Recommended Action

Do not respond to the email, click the embedded link or provide any personal information. Mark the email as spam or phishing, report it to the Information Security Team and block the sender to prevent future scam attempts.

EMAIL 11: Quick request before my flight

Risk Level: High

Verdict: SUSPICIOUS

Technical Header Analysis

Sender: Suresh Iyer (CFO)<suresh.iyer@solvexindustries.com>

Reply-To: s.iyer.cfo.travel@outlook.com

Return-Path: suresh.iyer@solvexindustries.com

SPF: Pass

DKIM: Pass

DMARC: Pass

Encryption: Yes (TLS 1.3)

Observation

At first glance, the email appears legitimate because it originates from the official **solvexindustries.com** domain and successfully passes SPF, DKIM and DMARC authentication. However, a closer inspection reveals that the **Reply-To** address redirects responses to an external **Outlook.com** account instead of the company's official domain. This inconsistency is a significant red flag, as genuine corporate emails normally use the same organisational domain for replies. The mismatch suggests that the attacker intends to divert further communication outside the company's email infrastructure.

Email Content Analysis

The email claims that the Chief Financial Officer (CFO) is about to board a flight and urgently requires the recipient to purchase **five Amazon gift cards worth ₹5,000 each**. The recipient is instructed to send the gift card codes through email and is assured that reimbursement will be provided later. The sender also requests that the recipient **avoid calling the office** because of poor mobile network coverage while boarding. This discourages independent verification and attempts to isolate the recipient from confirming the request. Gift card requests from senior executives are a well-known indicator of **Business Email Compromise (BEC)** attacks.

Social Engineering Analysis

The attacker combines several social engineering techniques to manipulate the recipient.

- **Authority:** Impersonates the company's Chief Financial Officer.

- **Urgency:** Claims the request must be completed within the next 20 minutes.
- **Isolation:** Asks the recipient not to call the office for verification.
- **Trust Exploitation:** Promises reimbursement later to reduce suspicion.

Link / Attachment Analysis

No links or attachments are included in the email.

Indicators of Compromise (IOCs)

- External Reply-To address: s.iyer.cfo.travel@outlook.com
- Gift card purchase request.
- Request to send gift card codes via email.
- Unusual financial request outside normal business procedures.

Risk Justification

Although the email successfully passes SPF, DKIM and DMARC authentication, the external Reply-To address and unusual request for gift cards strongly indicate a **Business Email Compromise (BEC)** attack. The urgency, request for secrecy and attempt to bypass normal verification procedures significantly increase the likelihood of fraud. Processing the request could result in financial loss.

Recommended Action

Do not purchase or send gift card codes. Verify the request directly with the CFO using an official communication channel such as the company phone number or Microsoft Teams. Report the email to the Information Security Team for further investigation.

EMAIL 12: Reminder: Mandatory Security Awareness Training – Due This Friday

Risk Level: Low

Verdict: SAFE

Technical Header Analysis

Sender: Information Security Team – Solvex Industries<infosec@solvexindustries.com>

Reply-To: infosec@solvexindustries.com

Return-Path: infosec@solvexindustries.com

SPF: Pass

DKIM: Pass

DMARC: Pass

Encryption: Yes (TLS 1.3)

Observation

The sender, Reply-To and Return-Path addresses are consistent and belong to the official **solvexindustries.com** domain. SPF, DKIM and DMARC authentication checks all passed successfully, confirming that the email was sent through the organisation's legitimate mail server. The email was also transmitted using TLS 1.3 encryption, and no suspicious header anomalies were identified.

Email Content Analysis

The email reminds employees to complete the mandatory **Q3 Security Awareness Training** before the specified deadline. It explains that the training covers topics such as phishing identification, password hygiene and safe attachment handling. Employees are instructed to access the course through the company's internal learning portal using their employee credentials. The content is relevant to the organisation's security practices and does not request passwords, financial information or any confidential data. The instructions follow a standard corporate training process and are consistent with legitimate internal communication.

Social Engineering Analysis

No social engineering techniques were identified.

Link Analysis

The email directs employees to **learn.solvexindustries.com**, which is an internal company learning portal. The domain is consistent with the organisation's infrastructure and does not display any signs of impersonation or URL manipulation.

Indicators of Compromise (IOCs)

No Indicators of Compromise (IOCs) were identified.

Risk Justification

This email is classified as **SAFE** because it originates from the organisation's legitimate Information Security Team, successfully passes SPF, DKIM and DMARC authentication, and contains a routine security awareness training reminder. The message does not request sensitive information, modify existing processes or display characteristics commonly associated with phishing attacks.

Recommended Action

The recipient can safely access the internal learning portal and complete the mandatory training before the deadline. Employees should continue following standard organisational security practices and report any suspicious emails to the Information Security Team.

EMAIL 13: Pending Invoice – Please Review & Process on Priority

Risk Level: High

Verdict: SUSPICIOUS

Technical Header Analysis

Sender: Accounts Receivable<accounts.receivable@shreeganesh-logistics.in>

Reply-To: accounts.receivable@shreeganesh-logistics.in

Return-Path: mailer@shreeganesh-logistics.in

SPF: Fail (Domain not authorised to send)

DKIM: None

DMARC: Fail

Encryption: No (TLS Not Enabled)

Observation

The email claims to be from **Shree Ganesh Logistics**, but the technical headers reveal multiple authentication failures. SPF validation failed because the sending server was not authorised to send emails on behalf of the claimed domain. No DKIM signature was present, and DMARC validation also failed. The email was transmitted without TLS encryption and originated from an unrelated shared hosting server rather than a trusted corporate mail server. These indicators significantly reduce the credibility of the email and strongly suggest sender spoofing or malicious activity.

Email Content Analysis

The email requests immediate processing of an overdue transport invoice and claims that the attached document contains delivery challans and updated GST details. To convince the recipient, it explains that the file was created using an older billing system and instructs the user to **enable editing and macros** if prompted so that all invoice tables display correctly. Legitimate invoices do not require users to enable Microsoft Office macros simply to view their contents. This instruction is a well-known tactic used by attackers to persuade victims to execute malicious code embedded within Office documents.

Social Engineering Analysis

- **Urgency:** Requests immediate processing of an overdue invoice.
- **Business Context:** Uses transport invoices and GST documents to appear legitimate.
- **Trust Manipulation:** Provides a convincing explanation that macros are required because the document was created using an older billing system.
- **Execution Trigger:** Directly instructs the recipient to enable editing and macros, increasing the chance of malware execution.

Attachment Analysis

The email contains a **macro-enabled Microsoft Word document** named:

Pending_Invoice_Challan_Details.docm

Macro-enabled **.docm** files can contain embedded VBA scripts capable of downloading malware, executing malicious commands or installing ransomware once macros are enabled. Since the email explicitly instructs the recipient to enable macros, the attachment should be considered highly suspicious and must not be opened on a production system.

Indicators of Compromise (IOCs)

- Sender email: accounts.receivable@shreeganesh-logistics.in
- Return-Path: mailer@shreeganesh-logistics.in
- Source IP: 41.203.88.17
- Attachment: Pending_Invoice_Challan_Details.docm
- Embedded URL:
hxxp://shreeganesh-logistics.in.invoice-view-secure.com/download?file=inv2207

Risk Justification

This email exhibits multiple indicators of a malicious document delivery campaign. The failed email authentication checks, shared hosting infrastructure, macro-enabled attachment, embedded download link and explicit instruction to enable macros together provide strong evidence of an attempted malware infection. If the recipient enables macros, malicious code could execute on the system, leading to malware installation, credential theft or ransomware deployment.

Recommended Action

Do not open the attachment or enable macros. Quarantine the email immediately and report it to the Information Security Team. If analysis of the document is required, perform it only within an isolated sandbox environment.

Per-Email Findings

Email No.	Subject	Verdict	Risk Level	Key Findings
Email 01	Password Expiry Reminder – Action Needed Within 5 Days	SAFE	Low	Official company domain, SPF/DKIM/DMARC passed, no suspicious links or requests.
Email 02	URGENT: Your Mailbox Storage is FULL – Verify Now to Avoid Suspension	SUSPICIOUS	High	Lookalike domain, phishing URL, SPF/DKIM/DMARC failed, credential harvesting attempt.
Email 03	Invoice SI-4471 & Updated Bank Details for Future Payments	MEDIUM RISK	Medium	Authentication passed, but requests bank account change and uses a different Reply-To domain, possible BEC attempt.
Email 04	Revised Leave & Work-From-Home Policy – Effective 15 July 2026	SAFE	Low	Legitimate HR communication, official company domain, authentication checks passed.
Email 05	Confidential – Immediate Wire Transfer Required (Time Sensitive)	SUSPICIOUS	High	Executive impersonation, lookalike domain, urgent wire transfer request, no email authentication.
Email 06	'Q1_Vendor_Compliance_Report.xlsx' has been shared with you	SAFE	Low	Genuine Google Drive notification, official Google domain, authentication checks passed.
Email 07	Unusual sign-in activity detected on your Microsoft account	SUSPICIOUS	High	Typosquatted Microsoft domain, phishing link, failed authentication, credential theft attempt.

Email No.	Subject	Verdict	Risk Level	Key Findings
Email 08	Exciting Career Opportunity – Senior Finance Role	MEDIUM RISK	Medium	ZIP attachment, requests PAN card and salary slip, verification required.
Email 09	Your TallyPrime Cloud Subscription Renewal Invoice	SAFE	Low	Official Tally domain, secure authentication, legitimate renewal process, no suspicious payment changes.
Email 10	Congratulations!!! You Have Won USD 1,000,000	SUSPICIOUS	High	Lottery scam, advance fee fraud, suspicious domains, failed authentication, requests personal information and payment.
Email 11	Quick Request Before My Flight	SUSPICIOUS	High	CFO impersonation, external Reply-To address, urgent gift card request, classic BEC attack.
Email 12	Reminder: Mandatory Security Awareness Training	SAFE	Low	Genuine internal security awareness reminder, official company domain, authentication passed.
Email 13	Pending Invoice – Please Review & Process on Priority	SUSPICIOUS	High	Macro-enabled .docm attachment, failed authentication, suspicious download link, likely malware delivery attempt.

Consolidated Indicators of Compromise (IOCs)

IOC Type	IOC Value	Related Email(s)	Reason
Email Address	support@solvex-industries-helpdesk.com	Email 02	Lookalike IT support sender used for phishing.
Email Address	recovery-team@mail-secure-verify.net	Email 02	Suspicious external Reply-To address.
Email Address	bounce@mail-secure-verify.net	Email 02	Suspicious Return-Path address.
Domain	solvex-industries-helpdesk.com	Email 02	Lookalike domain impersonating Solvex Industries.
Domain	mail-secure-verify.net	Email 02	External domain used for replies.
IP Address	193.41.77.108	Email 02	Unknown external mail server.
URL	hxxp://solvex-industries-helpdesk.verify-account-secure.com/mailbox/confirm?user=aditya.rao	Email 02	Credential phishing URL.
Email Address	rajeev.malhotra.md@gmail-corpmail.com	Email 05	Fake executive email address.
Domain	gmail-corpmail.com	Email 05	Lookalike corporate email domain.
IP Address	45.137.22.9	Email 05	External SMTP relay server.
Email Address	security-noreply@micos0ft-online.com	Email 07	Fake Microsoft sender.
Domain	micos0ft-online.com	Email 07	Typosquatted Microsoft domain.
IP Address	77.91.134.6	Email 07	VPN exit node used to send email.
URL	hxxp://login.micos0ft-online.com/secure/verify-identity?ref=aditya.rao	Email 07	Credential phishing page.

IOC Type	IOC Value	Related Email(s)	Reason
Attachment	JD_SeniorFinanceManager_Client.zip	Email 08	Unknown ZIP attachment requiring verification.
Email Address	claims.department009@yandex-mailer.com	Email 10	Fake lottery sender.
Email Address	agent.williams.claims@outlook-verify.info	Email 10	Fraudulent Reply-To address.
Domain	lottery-verify.info	Email 10	Fake lottery verification domain.
IP Address	185.220.101.44	Email 10	Suspicious mail server.
URL	hxxp://claim-your-prize-now.lottery-verify.info/claim?ref=44921	Email 10	Lottery scam URL.
Email Address	s.iyer.cfo.travel@outlook.com	Email 11	External Reply-To used in executive impersonation.
Email Address	accounts.receivable@shreeganesh-logistics.in	Email 13	Suspicious sender.
Domain	shreeganesh-logistics.in	Email 13	Domain associated with malicious invoice.
IP Address	41.203.88.17	Email 13	Shared hosting mail server.
URL	hxxp://shreeganesh-logistics.in.invoice-view-secure.com/download?file=inv2207	Email 13	Suspicious download URL.
Attachment	Pending_Invoice_Challan_Details.docm	Email 13	Macro-enabled Word document likely used for malware delivery.

Recommendations

1. Employees should always verify the sender's email address and carefully examine the Reply-To address before responding to any email, especially those requesting financial transactions or sensitive information.
2. Requests involving changes to bank account details, urgent fund transfers or confidential financial information should always be verified through an independent communication channel such as a phone call or an official company communication platform.
3. Users should avoid opening unexpected attachments or clicking on links received from unknown or untrusted senders. Extra caution should be exercised when dealing with ZIP files or macro-enabled Office documents.
4. Email authentication mechanisms such as SPF, DKIM and DMARC should be reviewed during email analysis. However, these checks should not be considered the only factor in determining whether an email is legitimate, as attackers may still use authenticated accounts for phishing or impersonation attacks.
5. Regular security awareness training should be conducted to help employees identify common social engineering techniques such as urgency, authority, fear, financial rewards and impersonation.
6. Any suspicious email should be reported immediately to the Information Security Team so that appropriate investigation and response actions can be taken before the threat spreads within the organisation.
7. The organisation should implement advanced email filtering, anti-phishing protection and attachment scanning to minimise the delivery of malicious emails to end users.

Conclusion

This investigation helped identify which emails were legitimate and which could potentially pose a security risk. By analysing the email headers, content, attachments, links and social engineering techniques, each email was successfully classified as **Safe, Medium Risk or Suspicious**. This project also showed that email security is not only about technical checks but also about carefully understanding the context and intent behind every email. Overall, it was a valuable hands-on exercise that improved my understanding of phishing attacks, Business Email Compromise (BEC) and email threat analysis.